

HRMS Platform: Phase-wise Delivery Plan (v1.0)

Companion to `HRMS_Project_Blueprint.pdf` (referred to as **BP**; "BP §9" means section 9 of the PDF). Blueprint = *what and how it is built*. This file = *in what order, with what gates*.

Working name: OrgHub HRMS Stack (**default**): Next.js + TypeScript, MongoDB replica set (see ADR-001), Redis, MinIO, React Native, self-hosted in your data center. **Cadence:** 2-week sprints. Durations below assume a team of about 6 to 8 (see BP §19.1). Fewer people means longer phases, not fewer gates.

1. Ground Rules (apply to every phase)

1.1 Engineering standards

Area	Rule
Repo	Monorepo (pnpm + Turborepo), structure as in BP §6
Branching	Trunk-based: short-lived feature branches, PR required, 1+ reviewer, protected <code>main</code> , squash merge
Commits	Conventional Commits, enforced by commitlint
Language	TypeScript strict; no <code>any</code> without a comment explaining why
Validation	Zod schema for every API input, shared by client and server
Authorization	Checked in the service layer on every call, plus tenant filter (<code>companyId</code>) in every query (BP §2.3)
Money	Integer paise or Decimal128; never floats
Time	Store UTC; attendance also stores local business date + timezone
Secrets	Vault / env secrets only; never in Git or images
Migrations	Versioned, backward compatible (expand, migrate, contract)
Docs	OpenAPI generated from Zod; one ADR per significant decision; runbook per operational procedure

1.2 Environments

Env	Purpose	Data
Local	Docker Compose (app, Mongo replica set, Redis, MinIO, mailpit)	Seed data
Dev/CI	Ephemeral, per pipeline run	Test fixtures
Staging	Mirrors production topology	Anonymized copy
Production	Live	Real

1.3 CI quality gates (a PR cannot merge unless all pass)

Lint, typecheck, unit tests, integration tests (real DB), dependency audit, container scan, coverage threshold on `packages/core` (start 70%, raise to 80%), permission-matrix tests, and bundle-size budget for the web app.

1.4 Definition of Ready (task can enter a sprint)

- Linked to a BP section and has acceptance criteria
- Roles and permissions affected are listed
- Design (Figma link) exists if the task has UI
- Dependencies are done or scheduled earlier in the same sprint

1.5 Definition of Done (task can be closed)

- Permission checks implemented and tested per role; tenant isolation tested
- Validation, loading, empty and error states handled
- Audit log entries for sensitive actions
- Mobile layout and keyboard accessibility checked
- Metrics and structured logs added
- OpenAPI and docs updated; migration and rollback tested
- Deployed to staging and demoed

1.6 Task ID format

`P{phase}-{EPIC}-{nn}`, for example `P2-PUNCH-03`. Use these IDs in branches, PRs and AI prompts.

2. Decisions to Lock Before Coding (ADRs)

ADR	Decision	Default in BP	Alternative	Decide by
001	Primary database	MongoDB replica set	PostgreSQL + PostGIS (recommended for payroll and reporting; changes BP §7, §9.4, §16)	Phase 0, week 2
002	Mobile approach	React Native (Expo dev build)	PWA for non-attendance features only	Phase 0, week 2
003	Auth	Auth.js + TOTP MFA	Keycloak (if SSO/SAML needed)	Phase 0, week 3
004	Object storage	MinIO	Ceph / SeaweedFS / NAS with S3 gateway (check licensing)	Phase 0, week 3
005	Orchestration	Docker Compose first	k3s/Kubernetes later	Phase 0, week 3
006	Hosting	Own data center	Colocation rack in India	Phase 0, week 1
007	Statutory scope at launch	Single entity, India, listed states	Multi-state / multi-entity	Phase 0, week 2
008	Retention periods	Selfies/raw location 90 days; HR/payroll 8 years	Per legal advice	Phase 0, week 4
009	Tenancy	Single company, multi-tenant-ready (<code>companyId</code> everywhere)	Fully single-tenant	Phase 0, week 1

Rule: no Phase 1 work that depends on an undecided ADR starts. ADR-001 gates the data model, so it is the first decision to close.

3. Roadmap Overview

Phase	Name	Duration	Release milestone	Gate to pass
0	Discovery, Design and Foundation	4 weeks	none	G0: scope, designs, ADRs signed; "hello world" deployed to staging via CI
1	Platform Core	8 weeks	R0 Internal alpha	G1: all roles log in with MFA; employee master; audit trail; staging stable
2	Workflow Engine + Attendance and Geofencing	8 weeks	R1a Attendance beta (IT dept)	G2: geofenced punch works on real devices; exceptions flow end to end
3	Leave, Calendars, Reports v1 and Pilot	6 weeks	R1 Pilot (one department, 4 weeks live)	G3: pilot signed off by HR; zero critical bugs open
4	Payroll, Expenses and Tax	12 weeks	R2 Parallel payroll (2-3 cycles)	G4: payroll output matches current process; CA sign-off
5	Hardening and Production Go-live	6 weeks	R3 Production GA	G5: go/no-go checklist (section 10) signed
6	Talent and Growth Modules	12 weeks	R4	G6: spreadsheets retired for hiring/performance/assets
7	Advanced and Scale	ongoing	R5+	per roadmap

Timeline note: sequential total to production GA is about 44 weeks (10 months). Phase 4 can start its design and rules-layer work during Phase 3 if you have enough engineers, which brings GA closer to 8 to 9 months. Do not compress Phase 5.

```

Phase 0 |####|
Phase 1      |#####|
Phase 2          |#####|
Phase 3              |#####|
Phase 4                  |#####| (design work may
overlap Phase 3)
Phase 5                      |#####|
Phase 6                          |#####|
Phase 7                              ongoing

```

Why this order: Core HR and RBAC are the foundation of everything. The workflow engine is needed by regularization (Phase 2) before leave (Phase 3) can reuse it. Payroll depends on stable attendance and leave, and is the highest-risk module, so it comes after the daily-use modules are proven in a pilot.

PHASE 0: Discovery, Design and Foundation (4 weeks)

Goal: remove ambiguity before writing product code, and prove the delivery pipeline end to end.

Tasks

ID	Task	Layer	BP
P0-DISC-01	Workshops with HR, Finance, Admin, IT: collect current leave, attendance, salary and approval policies; sample payslip; current reports	Product	1, 11
P0-DISC-02	Finalize role list and the permission matrix per module	Product	2
P0-DISC-03	MoSCoW scope for v1 (Must/Should/Could/Won't); success metrics (adoption, approval turnaround, payroll accuracy)	Product	1, 3
P0-DES-01	User journeys for Employee, Manager, HR, Accountant, Admin	Design	12
P0-DES-02	Design system in Figma: tokens, components, light/dark, accessibility rules	Design	14
P0-DES-03	Wireframes and clickable prototype: dashboards, clock-in with map, leave apply, approvals inbox, geofence editor, employee profile	Design	14
P0-DES-04	Usability test with 3 to 5 real staff; revise	Design	14
P0-ARCH-01	ADR-001 to ADR-009 decided and written	Architecture	5
P0-ARCH-02	Domain model/ERD for Phase 1 and 2 entities; index plan	Architecture	7
P0-ARCH-03	API conventions, error format, pagination, idempotency, versioning	Architecture	13
P0-ARCH-04	Threat model (STRIDE) for auth, attendance, payroll, file upload; data classification	Security	8
P0-INFRA-01	Provision VMs/servers; VLANs; firewall default-deny; VPN + bastion	Infra	16
P0-INFRA-02	DNS, TLS certificates, reverse proxy	Infra	16

ID	Task	Layer	BP
P0-INFRA-03	Git server, container registry, CI runners, Vault	Infra	16, 17
P0-INFRA-04	Staging stack: DB replica set, Redis, object storage; encrypted volumes	Infra	16
P0-INFRA-05	Monitoring skeleton: Prometheus, Grafana, Loki, alerting to chat/email	Infra	16
P0-REPO-01	Monorepo bootstrap: pnpm, Turborepo, TS strict, ESLint, Prettier, Husky, commitlint	DevOps	6
P0-REPO-02	<code>packages/config</code> with Zod env validation; <code>packages/shared</code> (errors, constants, date and money utils)	Backend	6
P0-REPO-03	Base Next.js app with <code>/api/health</code> and <code>/api/ready</code> ; Pino logging with request IDs; Dockerfiles (standalone build)	Backend	4
P0-REPO-04	CI pipeline: lint, test, build, scan, push image, deploy to staging, smoke test	DevOps	17
P0-REPO-05	Local <code>docker-compose.dev.yml</code> (DB replica set, Redis, MinIO, mailpit) and seed script	DevOps	6
P0-LEGAL-01	DPDP gap checklist; draft employee privacy notice and location-consent text; retention schedule	Legal	9, 18
P0-QA-01	Test strategy document; choose tools (Vitest, Playwright, k6)	QA	17

Week plan

- **Week 1:** workshops, ADR-006/009, infra procurement or colo booking, repo bootstrap
- **Week 2:** ADR-001/002/007, ERD, design system, infra VLANs/VPN, CI skeleton
- **Week 3:** wireframes and prototype, ADR-003/004/005, staging stack, monitoring
- **Week 4:** usability test, threat model, legal drafts, "hello world" through the full pipeline, backup/restore test on staging

Acceptance criteria

- A commit to `main` produces an image, deploys to staging, and passes smoke tests without manual steps
- Staging database backup is restored successfully into a scratch instance
- All ADRs are accepted and recorded in `docs/adr/`
- Figma prototype approved by HR and Finance leads

Gate G0: scope, designs and ADRs signed off; pipeline proven; infra access works only through VPN and bastion. **Risks:** hardware procurement delay (mitigate: start on VMs or a colo rack); policy ambiguity (mitigate: written sign-off on policies).

PHASE 1: Platform Core (8 weeks, 4 sprints)

Goal: a secure multi-role platform with organization structure, employee master and a full audit trail. After this phase the system holds real employee data.

Epics and tasks

ID	Task	Layer	BP
AUTH			
P1-AUTH-01	User model, Argon2id password hashing, login, logout, sessions (HTTP-only cookies)	Backend	8.1
P1-AUTH-02	TOTP MFA enrollment/verify, recovery codes, account lockout, login rate limiting	Backend	8.1
P1-AUTH-03	Invite/activation and password reset flows; email templates	Full stack	8.1
P1-AUTH-04	Session list and revoke; refresh-token rotation for mobile (API ready)	Backend	8.1
P1-AUTH-05	Step-up authentication hook for sensitive actions	Backend	2.2
RBAC			
P1-RBAC-01	Roles, permissions, scopes models; seed system roles and permission keys	Backend	2
P1-RBAC-02	<code>can()</code> engine with scopes (self, team, department, location, company) and reporting-line resolver	Backend	2.3
P1-RBAC-03	Tenant-scoped repository base class enforcing <code>companyId</code>	Backend	6
P1-RBAC-04	Admin UI: users, roles, permission editor, effective-permission viewer	Frontend	14
P1-RBAC-05	Automated permission-matrix tests (every role x every endpoint)	QA	17
ORG			
P1-ORG-01	Company settings, legal entity, departments, designations, grades, cost centers	Full stack	7

ID	Task	Layer	BP
P1-ORG-02	Locations (address only for now; geofence fields added in Phase 2)	Full stack	7
P1-ORG-03	Reporting hierarchy; org chart view (zoom, search)	Full stack	14
P1-ORG-04	Custom fields framework (definition + validation + rendering)	Full stack	20
EMP			
P1-EMP-01	Employee master: personal, contact, job, bank/ID (field-encrypted), status	Backend	7
P1-EMP-02	Effective-dated job history (designation, manager, location, department)	Backend	7.1
P1-EMP-03	Employee directory and profile UI with tabs, masking of sensitive fields	Frontend	14
P1-EMP-04	Document vault: upload via signed URLs, type/size checks, antivirus scan, verification status	Full stack	8.2
P1-EMP-05	Profile change requests (temporary simple approval; migrated to workflow engine in Phase 2)	Full stack	3
P1-EMP-06	Bulk import (CSV/Excel) with validation preview and error report; export	Full stack	3
AUDIT			
P1-AUDIT-01	Append-only audit service; automatic capture for create/update/delete, login, permission change, data export, salary view	Backend	8
P1-AUDIT-02	Audit viewer UI with filters (actor, entity, date)	Frontend	14
NOTIF			
P1-NOTIF-01	Notification service: in-app + email, templates, user preferences; BullMQ worker bootstrap	Backend	15

ID	Task	Layer	BP
P1-NOTIF-02	Notification center UI; real-time delivery gateway (SSE/Socket.IO)	Frontend	14, 15

FILE

P1-FILE-01	Object storage integration, signed URLs, per-bucket policies, encryption	Backend	5
------------	--	---------	---

SHELL

P1-SHELL-01	App shell: navigation by role, command palette (Ctrl+K), toasts, theming (light/dark), responsive layout	Frontend	14
P1-SHELL-02	Shared components: data table (server pagination, filters, column chooser, export), form kit, empty/loading/error states	Frontend	14
P1-SHELL-03	Role-based home dashboards (placeholders with real data cards: headcount, pending items)	Frontend	14.2

QA/OPS

P1-QA-01	E2E: login + MFA, create employee, role-restricted views	QA	17
P1-OPS-01	Production-like logging, metrics dashboards for auth and API latency; backup schedule on staging	Infra	16

Sprint plan

Sprint	Focus	Output
1.1	AUTH-01..03, RBAC-01..03, SHELL-01, ORG-01, AUDIT-01	Users can log in; roles exist; audit starts recording
1.2	AUTH-04/05, RBAC-04/05, ORG-02/03, EMP-01/02, FILE-01	Admin manages roles; org + employee records exist
1.3	EMP-03..05, SHELL-02, NOTIF-01/02, AUDIT-02	Full employee profile, documents, notifications
1.4	EMP-06, ORG-04, SHELL-03, QA-01, OPS-01, bug fixing, internal demo	R0 internal alpha

Acceptance criteria

- Every role can log in with MFA and sees only permitted navigation and data (verified by automated matrix tests)
- A manager cannot open an employee outside their reporting line by guessing an ID (IDOR test passes)
- Bank/ID/salary fields are encrypted in storage and masked in the UI by default
- Every create, update and delete of core data is visible in the audit log with actor, IP and before/after
- Load test: 200 concurrent users on login and directory, p95 under 400 ms

Gate G1: all above plus staging stable for one full sprint and internal demo accepted. **Risks:** over-engineering RBAC (mitigate: ship the scope model in BP §2, no more); sensitive-field encryption key handling (mitigate: Vault, documented rotation).

PHASE 2: Workflow Engine + Attendance and Geofencing (8 weeks, 4 sprints)

Goal: reliable geofenced attendance from a mobile app, with approvals handled by a reusable workflow engine.

Epics and tasks

ID	Task	Layer	BP
WF			
P2-WF-01	Workflow definitions (data-driven), request/steps model, state machine	Backend	10.3
P2-WF-02	Approver resolvers: reporting manager, manager's manager, role, specific user; parallel any/all	Backend	10.3
P2-WF-03	SLA timers, reminders, escalation, delegation (approver on leave), withdraw	Backend	10.3, 15.2
P2-WF-04	Approvals inbox UI: bulk approve, inline comments, keyboard shortcuts, mobile swipe	Frontend	14.4
P2-WF-05	Migrate profile change requests (P1-EMP-05) onto the engine	Full stack	3
P2-WF-06	Workflow definition editor for admins	Frontend	10.3
LOC			
P2-LOC-01	Work location model: GeoJSON center + radius, optional polygon, Wi-Fi BSSIDs, QR secret, timezone; geo indexes	Backend	7, 9.2
P2-LOC-02	Geofence editor UI (Leaflet): pin, radius slider, polygon draw, address search, "test a coordinate", employees covered preview	Frontend	14.4
P2-LOC-03	Employee-location assignment (fixed, flexible, remote, field) with validity dates	Full stack	9.2
POL			
P2-POL-01	Attendance policy model and versioning (strict/soft/off, selfie, accuracy, sources, grace, half/full day hours, penalties, auto punch-out)	Backend	9.6
P2-POL-02	Shifts (including night shifts crossing midnight), weekly offs, rosters	Backend	9.7
P2-POL-03	Policy, shift and roster admin UI; roster builder with drag-and-drop and conflict detection	Frontend	14.4
PUNCH			

ID	Task	Layer	BP
P2-PUNCH-01	POST /attendance/punch pipeline: auth, device check, accuracy, time, geofence, sequence, velocity (BP §9.3 steps 1 to 10)	Backend	9.3, 9.4
P2-PUNCH-02	Append-only punch store, idempotency key, flags and status model	Backend	7
P2-PUNCH-03	Anti-spoofing: mock-location flag handling, Play Integrity / App Attest verification, device binding and HR-approved device change	Backend	9.5
P2-PUNCH-04	Selfie capture upload, retention job; optional liveness/face-match scoring (async)	Full stack	9.5, 9.8
P2-PUNCH-05	Soft-policy flow: outside-fence punch becomes pending approval via workflow	Backend	9.3
P2-PUNCH-06	Wi-Fi BSSID / QR fallback verification	Backend	9.5
MOB			
P2-MOB-01	React Native app shell: login + MFA, secure token storage, push registration	Mobile	5
P2-MOB-02	Clock In/Out screen: live map with fence, accuracy badge, permission help, success state	Mobile	14.4
P2-MOB-03	Offline punch queue with sync and "offline punch" flag	Mobile	9.5
P2-MOB-04	Attendance history, calendar, regularization request	Mobile	14
P2-MOB-05	Consent screen for location and selfie; policy display	Mobile	9.8
DAY			
P2-DAY-01	Attendance-day calculation engine (first-in/last-out, worked minutes, late, early exit, overtime, status) with rule version	Backend	9.7

ID	Task	Layer	BP
P2-DAY-02	Nightly close job and on-demand recalculation; month lock/unlock with audit	Backend	15.2
P2-DAY-03	Auto punch-out job and missing-punch exceptions	Backend	9.6
P2-DAY-04	Regularization requests through workflow; recompute on approval	Full stack	9.7
P2-DAY-05	HR exceptions inbox; employee attendance calendar (color-coded, drill to punches and map)	Frontend	14.4
P2-DAY-06	Manager live "who is in" board (real-time)	Frontend	14.4
BIO			
P2-BIO-01	Biometric ingestion endpoint (device allow-list) mapping device user IDs to employees; same punch table	Backend	9.9
QA			
P2-QA-01	Geofence unit tests (inside, boundary, outside, polygon, GeoJSON lon/lat order)	QA	9.4
P2-QA-02	Field test: 10+ real devices, indoor/outdoor, different Android/iOS versions; tune default radius and accuracy limits	QA	9.5
P2-QA-03	k6 load test: 500 punches in 5 minutes	QA	17
P2-QA-04	E2E: punch inside, punch outside (soft), regularize, approve	QA	17

Sprint plan

Sprint	Focus
2.1	WF-01..03, LOC-01/02, POL-01, MOB-01
2.2	PUNCH-01/02/05, LOC-03, POL-02, MOB-02, WF-04
2.3	PUNCH-03/04/06, DAY-01..03, MOB-03/05, POL-03, QA-01
2.4	DAY-04..06, MOB-04, WF-05/06, BIO-01, QA-02..04, beta to IT department (R1a)

Acceptance criteria

- Server rejects or flags punches with: outside fence (per policy), accuracy over limit, mock location, unregistered device, impossible travel; each returns a clear reason code
- Punch result appears in the manager's live board within 2 seconds
- Replaying the same Idempotency-Key never creates a duplicate punch
- A night-shift punch-out after midnight is assigned to the correct shift date
- Recomputing a day after regularization changes status and records the rule version
- Field test shows 95%+ of legitimate indoor punches succeed with default settings, or defaults are adjusted until they do

Gate G2: beta users run for two weeks; punch success rate and false-block rate reported; no open critical or high bugs. **Risks:** GPS accuracy indoors (mitigate: soft mode first, BSSID/QR fallback); iOS/Android differences (mitigate: real-device matrix); store review delays for the mobile app (mitigate: internal distribution via MDM / TestFlight / private Play track).

PHASE 3: Leave, Calendars, Reports v1 and Pilot (6 weeks, 3 sprints)

Goal: complete the daily-use modules and prove them with one real department.

Epics and tasks

ID	Task	Layer	BP
P3-LV-01	Leave types and policies (accrual, carry-forward, caps, encashment flag, half-day/hourly, sandwich rule, notice, document required)	Backend	10.1
P3-LV-02	Leave ledger (append-only) and derived balances; accrual and carry-forward jobs	Backend	10.1, 15.2
P3-LV-03	Leave request: preview endpoint (balance, holidays, clashes), submit, cancel, reversal entries, all inside transactions	Backend	10.2
P3-LV-04	Leave workflows via engine (manager, then HR for long leave)	Backend	10.3
P3-LV-05	Apply-leave UI with live balance, date-range selection, clash warning; balances page	Frontend	14.4
P3-LV-06	Team leave calendar with holidays and clash overlay	Frontend	14.4
P3-LV-07	Admin UI for leave types, policies, manual balance adjustments (audited)	Frontend	10.1
P3-HOL-01	Holiday lists by location; weekly-off rules; company events	Full stack	7
P3-INT-01	Attendance-day integration: approved leave, holiday, WFH and OD mark days automatically; OD/WFH relax geofence	Backend	9.2, 9.7
P3-INT-02	Comp-off generation from overtime/holiday work; late-mark penalty rules	Backend	9.6
P3-REP-01	Report framework (filters, async generation, export to Excel/CSV/PDF, scheduled email)	Full stack	15.2
P3-REP-02	Reports v1: attendance summary, late/absent, leave balances/usage, headcount, joiners/leavers	Full stack	3
P3-DASH-01	Real dashboards per role (employee, manager, HR) with live data	Frontend	14.2
P3-NOTIF-01	Push notifications (FCM/APNs) and email digests; preferences	Full stack	15

ID	Task	Layer	BP
P3-ANN-01	Announcements, helpdesk-lite, directory polish, birthdays/anniversaries	Full stack	3
P3-MIG-01	Data import tooling for opening leave balances and historical attendance	Backend	3
P3-PILOT-01	Pilot plan: choose department, training sessions, support channel, feedback form, weekly review	Product	19
P3-QA-01	Full UAT scripts with HR; regression of Phases 1 to 2; accessibility pass (axe + manual)	QA	17
P3-QA-02	Load test: 9 AM spike (all employees punch within 10 minutes) plus dashboard reads	QA	17

Sprint plan

Sprint	Focus
3.1	LV-01..04, HOL-01, INT-01
3.2	LV-05..07, INT-02, REP-01, DASH-01, NOTIF-01
3.3	REP-02, ANN-01, MIG-01, QA-01/02, PILOT-01; start pilot (R1)

Acceptance criteria

- Leave balance always equals the sum of its ledger; approve/cancel/reverse leaves leave balances correct under concurrent requests (transaction tests)
- Sandwich rule, half-day, carry-forward and pro-rata accrual verified against HR's real sample cases
- Pilot department uses clock-in and leave daily for 4 weeks with at least 90% of punches made through the app
- Support tickets and feedback tracked; every critical bug closed before gate

Gate G3: HR signs off pilot results; list of changes for Phase 4 and 5 agreed.

PHASE 4: Payroll, Expenses and Tax (12 weeks, 6 sprints)

Goal: accurate, auditable, configurable payroll, proven by parallel runs against your current process. Highest-risk phase; do not skip validation.

Prerequisite: CA/payroll consultant engaged; current payslip format and statutory registrations documented; attendance and leave stable from the pilot.

Epics and tasks

ID	Task	Layer	BP
SAL			
P4-SAL-01	Salary components and safe formula engine (parser and evaluator, no <code>eval</code>), component types (earning, deduction, employer)	Backend	11.1
P4-SAL-02	Salary structures/templates; employee salary assignment with effective dating; CTC breakup tool	Full stack	11.2
P4-SAL-03	Salary revision workflow, arrears calculation	Backend	11
P4-SAL-04	Field-level encryption and step-up auth for salary views; access logging	Backend	8.2
RULES			
P4-RULES-01	Versioned statutory rules layer by financial year/state (PF, ESI, Professional Tax, LWF, gratuity, bonus)	Backend	11.1, 18
P4-RULES-02	TDS engine: old/new regime, projections, declarations, rebates, monthly spread	Backend	11, 18
P4-RULES-03	Rules admin UI with effective dates and change history	Frontend	11.1
RUN			
P4-RUN-01	Input collection: attendance/LOP, new joiners, exits, revisions, bonuses, arrears, loans, reimbursements	Backend	11.4
P4-RUN-02	Run state machine (Draft, Inputs Ready, Calculated, Review, Approved, Locked, Paid) with two-person approval rule	Backend	11.3
P4-RUN-03	Chunked, resumable, idempotent calculation worker with progress events	Backend	15.2
P4-RUN-04	Warnings engine (negative net, missing bank details, zero days, large variance)	Backend	11.4
P4-RUN-05	Payroll wizard UI: inputs, calculate with live progress, review variances with drill-down from net to rules, approve, publish	Frontend	14.4

ID	Task	Layer	BP
P4-RUN-06	Lock/unlock rules (unlock needs Super Admin + reason, audited); post-lock adjustments only via next run	Backend	11.3
SLIP			
P4-SLIP-01	Immutable payslip snapshots with rule version	Backend	7, 11.1
P4-SLIP-02	Payslip PDF generation (templated), storage, employee download, email notification	Full stack	15.2
P4-SLIP-03	Bank advice file generation (formats per your bank) and payment confirmation import	Backend	11.4
EXP			
P4-EXP-01	Expense categories and policy limits; claims with bill upload	Full stack	3
P4-EXP-02	Approval via workflow; payout through payroll component or bank file	Full stack	12.5
TAX			
P4-TAX-01	Investment declaration and proof upload/verification	Full stack	3
P4-TAX-02	Form 16 / 24Q data export and statutory reports (PF ECR, ESI, PT, TDS)	Backend	18
REP			
P4-REP-01	Payroll reports: register, variance, department cost, bank summary, statutory summaries	Full stack	3
RECON			
P4-RECON-01	Parallel-run reconciliation tool: import existing payroll output, compare per employee per component, explain differences	Full stack	11.1
QA			

ID	Task	Layer	BP
P4-QA-01	Golden-file tests: 50+ real salary cases (mid-month joiner, exit, LOP, arrears, regime change) with expected results from the CA	QA	17
P4-QA-02	Concurrency and rollback tests for run lock and payouts	QA	17
P4-QA-03	Load test: payroll of full headcount completes within agreed time	QA	17

Sprint plan

Sprint	Focus
4.1	SAL-01/02, RULES-01, QA-01 starts (golden cases collected)
4.2	SAL-03/04, RUN-01/02, RULES-02
4.3	RUN-03/04/05, SLIP-01
4.4	RUN-06, SLIP-02/03, REP-01, EXP-01/02
4.5	TAX-01/02, RULES-03, RECON-01; parallel run cycle 1
4.6	Fix findings, QA-02/03, parallel run cycle 2 (cycle 3 continues into Phase 5)

Acceptance criteria

- Golden-file tests pass 100%
- Parallel runs: zero unexplained differences against current payroll for at least 2 consecutive cycles (3 preferred)
- Locked run cannot be altered; every change after lock appears as an adjustment with audit trail
- Statutory rate or slab change is applied by adding a new rules version, with no code deployment
- Two-person rule verified (preparer cannot approve own run)

Gate G4: CA/payroll consultant written sign-off on calculations and statutory reports; Finance sign-off on payslip format and bank file. **Risks:** statutory edge cases (mitigate: golden files from real cases, CA review); scope creep into loans/multi-state (mitigate: ADR-007 scope held until after go-live).

PHASE 5: Hardening and Production Go-live (6 weeks, 3 sprints)

Goal: make the platform safe, recoverable and ready for the whole organization.

Tasks

ID	Task	Layer	BP
P5-SEC-01	Third-party penetration test; fix all critical/high; retest	Security	8, 17
P5-SEC-02	Secrets rotation test, key-recovery drill for field encryption, access review of all privileged accounts	Security	8.2
P5-SEC-03	WAF rules tuned, rate limits verified, security headers and CSP validated	Security	8.2
P5-PERF-01	Load test at 2x expected peak (punch spike, payroll run, report exports); tune indexes, queries, caching	Performance	14.5, 17
P5-PERF-02	Slow-query review; add missing indexes; connection pool sizing	Performance	7.4
P5-DR-01	Full disaster recovery drill: restore database and files to a clean environment; measure RPO/RTO; record in runbook	Infra	16.4
P5-DR-02	Failover drill: kill the database primary and an app node; verify automatic recovery and alerts	Infra	16
P5-OPS-01	Runbooks: deploy, rollback, failover, restore, certificate renewal, key rotation, incident response	Ops	16.4
P5-OPS-02	On-call rota, alert thresholds and escalation; status page; log retention	Ops	16.6
P5-OPS-03	Production environment build, configuration review, change freeze procedure	Infra	16
P5-DATA-01	Production data migration: employees, org, balances, salary, historical records; dry runs on staging; reconciliation reports	Backend	3
P5-UAT-01	Full UAT with HR, Finance, managers and selected employees; defect triage	QA	17
P5-A11Y-01	Accessibility audit on critical flows (WCAG 2.1 AA)	QA	14
P5-TRAIN-01	Training: role-based sessions, quick-start guides, short videos, in-app tours, FAQ	Product	14

ID	Task	Layer	BP
P5-LEGAL-01	Final privacy notice, consent text, retention configuration, DPDP checklist review	Legal	18
P5-CUT-01	Cutover plan: freeze date, migration window, rollback criteria, comms plan	Product	19
P5-PAY-01	Parallel payroll cycle 3 (if not completed) and first live payroll with Finance on standby	Finance	11

Acceptance criteria

- Pen test: zero open critical/high findings
- DR drill meets agreed RPO (target 15 minutes) and RTO (target 2 to 4 hours)
- Failover drill recovers without data loss and alerts fire correctly
- Load test at 2x peak meets performance targets (BP §14.5)
- Migrated data reconciles to source with signed difference report

Gate G5 / go-live checklist (see section 10): signed by product owner, HR lead, Finance lead, security lead and DevOps lead. **After go-live:** 2 to 4 weeks of hypercare (daily triage, fast-fix lane, daily health review).

PHASE 6: Talent and Growth Modules (12 weeks, 6 sprints)

Goal: retire the remaining spreadsheets and tools by adding people-growth modules on top of the proven core.

ID	Module	Key deliverables	BP
P6- REC	Recruitment (ATS)	Job openings, careers page, candidate kanban (drag-and-drop), interview scheduling and scorecards, offer letters with workflow, convert candidate to employee	3
P6- ONB	Onboarding	Templates by role, task assignment across HR/IT/Admin/Manager, e-sign documents, progress tracking	12.1
P6- OFF	Offboarding	Resignation workflow, notice computation, clearance checklist, exit interview, F and F settlement (uses payroll engine)	12.4
P6- PERF	Performance	Goals/OKRs, review cycles, self/manager/360 feedback, ratings calibration, 1:1 notes	3
P6- AST	Assets	Inventory, assignment and return, linked to onboarding/exit	3
P6- HELP	Helpdesk and letters	Ticket categories, SLA, template-based letter generation (offer, experience, salary certificate) with e-sign	3
P6- ENG	Engagement	Polls and surveys, kudos, anniversaries, richer directory	3
P6- ANA	Analytics v2	Attrition, hiring funnel, payroll cost trends, saved dashboards, scheduled reports	3, 14

Gate G6: each module passes DoD, role-matrix tests, UAT; adoption metrics measured at 30 days. Sequence suggestion: ONB/OFF first (touch payroll and assets), then REC, PERF, HELP, AST, ENG.

PHASE 7: Advanced and Scale (ongoing)

Prioritize by measured need. Candidates (BP §20):

- AI features: policy chatbot (permission-aware), resume screening, attrition risk, anomaly detection
- Face-recognition kiosk, beacons, field-visit tracking
- Multi-entity, multi-state, multi-company, white-labeling
- Public API and webhooks, SSO/SCIM, Slack/Teams approvals, Tally/Zoho Books integration
- Read replica or analytics store, search engine for global search

- Kubernetes migration, multi-site DR, zero-downtime upgrades at scale

Rule: every item needs an ADR, a business case and a pilot before general release.

9. Team Allocation by Phase

Role	P0	P1	P2	P3	P4	P5	P6
Product owner / BA	High	High	Med	High	High	High	Med
UI/UX designer	High	High	Med	Med	Med	Low	Med
Full-stack engineers (2 to 3)	Low	High	High	High	High	Med	High
Mobile engineer	-	Low	High	Med	Low	Low	Low
DevOps / SRE / DBA	High	High	Med	Med	Med	High	Med
QA engineer	Low	Med	High	High	High	High	Med
Security	Med	Med	Med	Low	Med	High	Low
CA / compliance advisor	Low	-	-	Low	High	Med	Low
Finance and HR SMEs	High	Med	Med	High	High	High	Med

10. Production Go-live Checklist (Gate G5)

Security

- ☐ Pen test complete, no open critical/high findings
- ☐ MFA enforced for admin, HR, Finance roles
- ☐ Database, Redis, object storage not reachable from the internet; only 443 open
- ☐ Secrets in Vault; none in Git or images; rotation tested
- ☐ Disk encryption on database, files and backups; field encryption verified

Reliability

- ☐ Database HA verified by failover drill
- ☐ Automated backups running; offsite encrypted copy; **restore tested within the last 7 days**
- ☐ Monitoring and alerts verified by deliberately triggering them
- ☐ Rollback procedure rehearsed

Functional

- ☐ UAT signed by HR, Finance, managers
- ☐ Parallel payroll differences resolved and signed by CA
- ☐ Data migration reconciled and signed
- ☐ Geofence defaults tuned from pilot data; soft/strict policy decision recorded

Compliance and people

- ☐ Privacy notice and consent text live; retention configured
 - ☐ Training delivered; support channel and hypercare rota ready
 - ☐ Communication to all employees sent; cutover and rollback criteria agreed
-

11. First 10 Working Days (start here)

Day	Action	Output
1	Place <code>HRMS_Project_Blueprint.pdf</code> and this file in <code>docs/</code> of the repo. Confirm ADR-006 (hosting) and ADR-009 (tenancy). Name the product owner.	Repo created, owners named
2	Decide ADR-001 (database) using the comparison; record it in <code>docs/adr/001-database.md</code>	Decision recorded
3	Book workshops with HR, Finance, Admin, IT; request current policies, sample payslip, leave rules, shift rules	Workshop calendar, document pack
4	Bootstrap monorepo (P0-REPO-01/02): pnpm, Turborepo, TypeScript strict, lint, commit rules	Repo skeleton in <code>main</code>
5	Base Next.js app with health endpoint, logging, Dockerfile (P0-REPO-03)	App runs in container
6	Local Docker Compose with database replica set, Redis, object storage, mail catcher (P0-REPO-05)	<code>docker compose up</code> works for every developer
7	CI pipeline skeleton (P0-REPO-04); request or provision servers/VMs (P0-INFRA-01)	Green pipeline
8	Start design system and wireframes (P0-DES-02/03); draft ERD for Phase 1	First Figma pages, ERD v0
9	Draft permission matrix from workshops (P0-DISC-02); start threat model	Matrix v1
10	Review: scope list (MoSCoW), open decisions, Phase 0 week-2 plan	Updated plan

12. How to Work With Your AI Assistant (prompt template)

Attach `HRMS_Project_Blueprint.pdf` and this plan, then use:

Context: HRMS platform. Follow HRMS_Project_Blueprint.pdf and HRMS_Phase_Plan.md.

Task ID: P2-PUNCH-01 (Phase 2, geofenced punch pipeline)

Relevant sections: BP §9.3, §9.4, §9.5, §7 (attendance_punches)

Constraints: service-layer authorization, companyId on every query, Zod validation,

idempotency key, append-only punch store, typed errors, Pino logging.

Deliver: schema + indexes, service, route handler, Zod schemas, unit + integration tests,

audit hooks, OpenAPI update, short README note.

Do not: change unrelated modules, add new infrastructure, hardcode policy values.

Before coding: list your assumptions and any open questions.

Work one task ID at a time, review the pull request like any other, and run the CI gates before merging. Never let the AI skip tests, permission checks or audit hooks to "move faster".

13. Change Control

- Scope changes during a phase go to a backlog; they enter only at sprint planning, with an impact note on the gate date.
- Any change to payroll rules, permissions or the data model needs an ADR or written note and a migration plan.
- Every gate (G0 to G6) has a named approver; a failed gate means fix, re-test and re-review, not "carry the risk forward".